ECHO to Veritas - Master Handoff

Updated: 2026-11-08. Local branch: `main`, based on `f817306` (remote `origin/main` was `50f1949` before this work). FreeLLMAPI is ECHO's verified primary conversational provider; deterministic commands, security gates and offline fallback are preserved; optional free browser speech is implemented.

What changed

1. **FreeLLMAPI is the primary brain.** Natural conversation goes to the FreeLLMAPI OpenAI-compatible gateway. `auto:reliable` is the default model and the gateway chooses the upstream route dynamically. OpenAI is ignored unless `ECHO_ALLOW_PAID_PROVIDER=true`; there is no mandatory paid provider.
2. **Security hardening.** ECHO sessions require a signed-in portal identity, are bound to the account `sub`, reject unapproved origins, use no shipped fallback secret, validate token format/expiry strictly, allowlist only `message` and `page`, bound all stores and rate-limit messages.
3. **Production security hardening (this release):**
- CORS origin allowlisting replaced reflected `origin: true` with explicit allowlist (403 on foreign origins, same-origin/preflight supported).
- Session secrets enforced: `SESSION_SECRET` ≥32 chars in production; `assertSessionSecretConfigured()` fails at startup if unset.
- `PORTAL_BOOTSTRAP_PASSWORD` required (≥16 chars) in production; seeds the principal's password; sample accounts receive random unusable hashes.
- Demo accounts (`/api/auth/demo-accounts`) return 404 in production; generic forgot-password response instead of password text.
- Production password policy: 12-char minimum for self-service changes; temporary one-time passwords for admin-created students/staff and resets.
- Login page: dev-only demo account panel; production shows "Secure sign■in — scrypt-hashed credentials and role■based access control."
- AppShell: dev-only instant role switcher hidden in production.
- StudentsStaffPage: shows temporary password in production enrollment/reset toasts.
- `server/utils/portalMode.ts`: production-mode detection.
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.
3. **Natural conversation.** Greetings, typos, follow-ups, page/role context, empathy, jokes, sensitive refusals, provider status and honest no-memory behavior are handled without inventing school records.
4. **Fuzzy commands.** Politeness, location questions, "pull up", "bring up", "where is" and location-aware navigation resolve locally. Compound plans are atomic and execute nothing if any part is unsupported. Ordinary prose with "and"/"or" stays conversational.
5. **Speech.** Free browser `speechSynthesis`, on/off, Stop, 0.8-1.5x speed, sentence streaming, no overlap, session-scoped settings and text fallback. A replacement provider can be registered at `window.EchoWidgetSpeechProviders`.
6. **Provider diagnostics.** Authenticated `/api/echo/provider` plus SSE `event: meta` reveal provider/model/route without keys, prompts or replies.

Verified provider evidence

Command: `ECHO_USE_DESKTOP_SETTINGS=true node tests/echo-freellm-provider.mjs`.

- Real local gateway, 292 models visible.
- Real multi-turn conversation; synthetic code `QX-7319` recalled on turn 2.
- Provider `freellmapi`, model `command-a-plus-05-2026`, route `cohere/command-a-plus-05-2026`; turns 1554 ms and 1580 ms.
- The live browser widget received the model-generated marker `PLUMAGE`.
- An earlier run routed to `qwen/qwen3.8-27b` via `groq`, confirming dynamic routing. Do not hardcode an upstream model in tests.
- Credentials were read from the existing FreeLLMAPI desktop store only with explicit opt-in, passed to the child server environment, never printed or written to the repository or browser.

Verified local checks

Check	Result
129 unit tests: config, commands, conversation, security	PASS
`tsc --noEmit`	PASS
production `vite build`	PASS, 9.1 s
full browser regression	PASS
live FreeLLMAPI provider test	PASS

Browser coverage includes login, typo commands, verified navigation feedback, context help, clipboard success/failure, Stop/reset/error recovery, speech on/off/speed/Stop/overlap/failure fallback, 390 px mobile, logout abort and second-account isolation. Browser regression uses fake SSE; only the opt-in test proves a real model.

Configuration contract

Server-only variables (never `VITE_*`, never frontend code):

```text
FREELLMAPI_BASE_URL=https://<public-https-gateway>/v1
FREELLMAPI_API_KEY=<secret>
FREELLMAPI_MODEL=auto:reliable
ECHO_ALLOW_PAID_PROVIDER=false
ECHO_SESSION_SECRET=<long random value>
SESSION_SECRET=<long random value>
PORTAL_BOOTSTRAP_PASSWORD=<16+ char production bootstrap secret>
```

- Development: with a key and no base URL, ECHO uses `http://127.0.0.1:31415/v1`; the FreeLLMAPI desktop app must be running.
- Production: explicit HTTPS only. Credentials in URLs, query strings, non-loopback HTTP and paths other than `/v1` are rejected.
- `PORTAL_BOOTSTRAP_PASSWORD` is required (≥16 chars) when `NODE_ENV=production` or running on Vercel; seeds the principal's password; sample accounts get random unusable hashes.
- Legacy `FREELMAPI_*` and `ECHO_MODEL_*` aliases still work.
- `/api/echo/provider` reports configured/reachable/model/base host; it never exposes the key.

Vercel status and required action

The deployed site still runs the old build. A model-only prompt received the old scripted welcome, so production is not provider-connected. Vercel cannot reach this PC's loopback gateway at `127.0.0.1:31415`.

To enable FreeLLMAPI in production:

1. Expose the gateway at a public HTTPS origin (an HTTPS tunnel or a hosted FreeLLMAPI-compatible gateway).
2. Add `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL`, `ECHO_SESSION_SECRET` and `SESSION_SECRET` in Vercel Project Settings -> Environment Variables.
3. Redeploy and sign in.
4. Check `/api/echo/provider` for `configured: true`, `reachable: true`.
5. Send a model-only prompt and confirm the SSE `meta` provider/model.
6. If the values are absent, the deployment intentionally uses deterministic fallback. HTTP 200 or Ready alone is not provider proof.

No credentials were exposed to frontend code. No paid provider is enabled.

Security status

`tests/echo-security.test.ts`: 135/135 PASS (including 6 portal-security gate tests). Fixed issues: anonymous issuance, unapproved origins, usable public fallback secret, malformed expiry, token suffix, unsupported fields, account binding, page-context injection, unbounded state and rate limiting.

New in this release:

- CORS origin allowlisting replaced reflected `origin: true` with explicit allowlist (403 on foreign origins, same-origin/preflight supported).
- Session secrets: `SESSION_SECRET` must contain at least 32 characters in production; `assertSessionSecretConfigured()` fails at startup if unset. `ECHO_SESSION_SECRET` added as alias.
- `PORTAL_BOOTSTRAP_PASSWORD` is required in production (`≥16 chars`); seeds random unusable hashes for sample accounts; only the bootstrap principal logs in.
- Demo accounts (`/api/auth/demo-accounts`) return 404 in production; generic forgot-password response instead of password text.
- Production password policy: 12-character minimum for self-service changes; temporary one-time passwords for admin-created students/staff and password resets.
- Login page: dev-only demo account panel; production shows "Secure sign■in — scrypt-hashed credentials and role■based access control."
- AppShell: dev-only instant role switcher hidden in production.
- StudentsStaffPage: shows temporary password in production enrollment/reset toasts.
- `server/utils/portalMode.ts`: production-mode detection (`NODE_ENV=production` or `VERCEL`).
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.

Residual, pre-existing or architectural:

- `server/utils/auth.ts` still uses a public default cookie secret when `SESSION_SECRET` is unset. Set it privately in production; it is the outer gate.
- Portal-wide reflected CORS remains at the API gateway level; ECHO origin checks are an additional gate, not a replacement.

- History/revocation are process-local; serverless instances do not share them.
- Stop cannot guarantee upstream cancellation/billing.
- Route confirmation covers view state, not lazy page-data loading.
- No physical-device or multi-browser matrix yet.

Key files

- `server/services/echo.ts`: authenticated router, account-bound sessions, origin/body/rate checks, SSE, page context.
- `server/services/echoConversation.ts`: natural conversation, provider priority, FreeLLMAPI/OpenAI config, status/probe, usage metadata.
- `server/index.ts`: authenticated `/api/echo/config`, `/api/echo/provider`, ECHO mount with cookie/Bearer portal identity.
- `src/lib/echoCommands.ts`, `src/lib/echoRecognition.ts`: registry, fuzzy commands, atomic plans, prose guards.
- `echo-web/widget/widget.js`: speech controller, credentials, page context, Stop/reset/copy.
- `tests/echo-security.test.ts`: 12 release gates.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.
- `tests/echo-conversation.test.ts`: 26 conversational/provider tests.
- `tests/echo-commands.test.ts`: 85 command tests.
- `tests/echo-browser.mjs`: full browser regression including speech.
- `tests/echo-freellm-provider.mjs`: opt-in real-provider verification.
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `server/utils/portalMode.ts`: production-mode detection.
- `.env.example`, `README.md`, `echo-web/README.md`: configuration contract.

Git and publication state

Implementation commit: `a49b9db8cacbb9c81490da4b209931ea45a1fa7`, pushed to `origin/main` with follow-up documentation commits (based on `f817306`).

Local `main` and `origin/main` now both at `a49b9db`. All verified changes were committed and pushed in a single batch.

`npm run test:echo`: **135/135 PASS**.
`tsc --noEmit`: PASS.
`npm run build`: PASS (2045 modules, 9.36 s).

Vercel did not auto-deploy the push. The workspace has no `.vercel` project link or deploy hook. Manual Vercel publish or Git-integration reconnect is required. After deploying, set environment variables (`SESSION_SECRET`, `ECHO_SESSION_SECRET`, `PORTAL_BOOTSTRAP_PASSWORD`, `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL`, `ECHO_ALLOW_PAID_PROVIDER`) in Vercel Project Settings -> Environment Variables and redeploy. Do not use `VITE_*` variables. After deploy, verify `/api/echo/provider` reports `configured: true` and `reachable: true`, and confirm a model-only prompt returns provider metadata. HTTP 200 or Ready status alone is not provider proof. Do not force-push.

Exact handoff paths

- Markdown:
`F:\Downloads\Veritas-Echo-Integration\echo-web\docs\ECHO-WEB-MASTER-HANDOFF.md`
- PDF:
`F:\Downloads\Veritas-Echo-Integration\echo-web\docs\ECHO-WEB-MASTER-HANDOFF.pdf`
- Backups: `F:\ECHO-Handoff\ECHO-WEB-MASTER-HANDOFF.md` and `.pdf`
- PDF generator: `python echo-web/docs/render_handoff.py` (requires reportlab;
output text is selectable/copyable).

Ready-to-copy continuation prompt

Continue ECHO/Veritas at `F:\Downloads\Veritas-Echo-Integration` on local `main`.
Read this handoff, `PENDING_WORK.md`, `RELEASE_VERIFICATION.md` and
`FUZZY_COMMANDS.md`, then inspect `git status`, `git log` and remotes. FreeLLMAPI
is ECHO's primary conversational brain and is verified locally; deterministic
commands, security gates, offline fallback and free browser speech are complete.
Do not recreate completed features, weaken tests or enable a paid provider.
Production Vercel still needs a public HTTPS FreeLLMAPI endpoint plus the
server-side environment variables; never expose keys to the frontend. After any
change, rerun the 129 tests, TypeScript, build, browser regression and the opt-in
provider test. Keep the Markdown/PDF handoffs and `F:\ECHO-Handoff` copies
current. Verify the deployed site after pushing; do not claim provider success
from HTTP 200 or Ready alone.